

	امتحان منتصف الفصل الدراسي الثاني ٢٠٢٦/٢٠٢٥		وزارة التعليم العالي المعهد العالي لتكنولوجيا المعلومات بمدينة بدر
	اسم المقرر: إدارة المخاطر وأمن تكنولوجيا المعلومات	كود المقرر: (S23)	
	المستوي: الرابع الشعبة: نظم المعلومات	عدد الأسئلة : ٣	
	أستاذ المقرر: د. عمرو حسن	مدة الامتحان: ساعتان	
	تاريخ الامتحان:	نموذج (1)	

اجب عن جميع الأسئلة التالية:

السؤال الاول: ضع علامة (✓) أمام العبارة الصحيحة وعلامة (x) أمام العبارة الخاطئة: [١٠ درجات- لكل نقطة درجة]

✓	١	يُعرف الخطر (Risk) بأنه نتاج التقاء التهديد مع ثغرة أمنية للوصول إلى الأصول.
X	٢	في مصفوفة القرار، يُقصد بـ "تجنب الخطر (Avoid)" شراء تأمين سيبراني لتحمل التكلفة.
✓	٣	تُحسب قيمة الخطر من خلال حاصل ضرب احتمالية حدوث الاختراق في حجم التأثير الناتج عنه.
✓	٤	يُعد التحديث المستمر للبرمجيات وأنظمة التشغيل أول درع حماية ضد الهجمات الإلكترونية.
X	٥	تقتصر الجريمة السيبرانية على سرقة البيانات فقط ولا تشمل إتلاف المستندات المعالجة إلكترونياً.
✓	٦	"السرية أو الموثوقية" تعني التأكد من عدم اطلاع الأشخاص غير المخولين على المعلومات.
X	٧	تهدف "التكاملية (Integrity)" إلى ضمان استمرار عمل النظام المعلوماتي دون انقطاع.
✓	٨	مصطلح "الهاكر" قد يُستخدم لوصف الشخص الذي يطور برمجيات الكمبيوتر ويدير أمن الأنظمة.
✓	٩	تعتبر "الديدان" و"أحصنة طروادة" من أنواع البرامج الخبيثة (Malware) المنتشرة.
✓	١٠	يُستخدم مصطلح (Phishing) للتعبير عن سرقة الهوية عبر رسائل البريد الإلكتروني الاحتيالية.
✓	١١	الطريقة الوحيدة لضمان خصوصية البريد الإلكتروني بشكل فعال هي عملية "التشفير".
X	١٢	الجدار الناري (Firewall) هو عبارة عن برامج فقط ولا يمكن أن يكون جهازاً مستقلاً.
✓	١٣	تُستخدم برامج (Packet Sniffers) لمراقبة وتجميع البيانات الداخلة والخارجة عبر الشبكة.
✓	١٤	وفقاً لمعيار NIST، تعتبر مرحلة "الاستعداد" هي الخطوة الأولى في منهجية الاستجابة للحوادث.
X	١٥	تقع مسؤولية حجب مؤشرات الاختراق وعزل الأنظمة المصابة ضمن مرحلة "الاكتشاف والتحليل".
✓	١٦	يُعد "الدستور" الأمني أكثر ثباتاً من "الخطة" لأنه لا يتغير بتغير الأفراد أو الظروف.
X	١٧	تقتصر شمولية الدستور السيبراني على الجوانب التقنية فقط دون التدخل في شؤون الأفراد.
✓	١٨	المعادلة الجوهرية لحساب قيمة الخطر هي حاصل ضرب الاحتمالية في حجم التأثير.
✓	١٩	في مرحلة "التحديد"، تُعتبر بيانات الموظفين والملكية الفكرية من الأصول الرقمية للمؤسسة.
X	٢٠	يُصنف الخطر في مصفوفة المخاطر باللون الأخضر إذا كان يتطلب استجابة فورية ودرجة.
✓	٢١	استراتيجية "المعالجة (Treat)" تعني سد الثغرة فوراً عبر تحديث الأنظمة أو تعزيز الإجراءات.
X	٢٢	يُقصد بـ "نقل الخطر (Transfer)" القبول بوجود الخطر مع مراقبته بشكل مستمر.
✓	٢٣	شراء تأمين سيبراني هو مثال تطبيقي على استراتيجية "نقل الخطر" لجهة خارجية.
✓	٢٤	استراتيجية "التجنب (Avoid)" تُستخدم عندما تكون المخاطر عالية جداً ولا يمكن إدارتها بفعالية.
X	٢٥	في مصفوفة المخاطر، يتم تحديد الألوان بناءً على عامل واحد فقط وهو احتمالية الحدوث.

√	٢٦	"تحليل الثغرات" يساعد المؤسسة في معرفة مدى صمود نظامها الأمني الحالي أمام التهديدات.
√	٢٧	يجب أن يتضمن الدستور الأمني تحديداً دقيقاً للأدوار والمسؤوليات لضمان عدم وجود ثغرات في المساءلة.
X	٢٨	تُعد "خطة استمرارية الأعمال" جزءاً اختيارياً في الدستور ولا ترتبط بالتعافي من الاختراقات.
√	٢٩	إذا كان حاصل ضرب (الاحتمالية × التأثير) يقع في أعلى نطاق التقييم، يُعطى اللون الأحمر.
X	٣٠	الدستور السيبراني القوي يضمن منع وقوع العواصف الرقمية بنسبة ١٠٠٪.
√	٣١	يُعد "الدستور" الأمني أكثر ثباتاً من "الخطة" لأنه لا يتغير بتغير الأفراد أو الظروف.
X	٣٢	تقتصر شمولية الدستور السيبراني على الجوانب التقنية فقط دون التدخل في شؤون الأفراد.
√	٣٣	المعادلة الجوهرية لحساب قيمة الخطر هي حاصل ضرب الاحتمالية في حجم التأثير.
√	٣٤	في مرحلة "التحديد"، تُعتبر بيانات الموظفين والملكية الفكرية من الأصول الرقمية للمؤسسة.
X	٣٥	يُصنف الخطر في مصفوفة المخاطر باللون الأخضر إذا كان يتطلب استجابة فورية ودرجة.
√	٣٦	استراتيجية "المعالجة (Treat)" تعني سد الثغرة فوراً عبر تحديث الأنظمة أو تعزيز الإجراءات.
X	٣٧	يُقصد بـ "نقل الخطر (Transfer)" القبول بوجود الخطر مع مراقبته بشكل مستمر.
√	٣٨	شراء تأمين سيبراني هو مثال تطبيقي على استراتيجية "نقل الخطر" لجهة خارجية.
√	٣٩	استراتيجية "التجنب (Avoid)" تُستخدم عندما تكون المخاطر عالية جداً ولا يمكن إدارتها بفعالية.
X	٤٠	في مصفوفة المخاطر، يتم تحديد الألوان بناءً على عامل واحد فقط وهو احتمالية الحدوث.
√	٤١	ملفات تعريف الارتباط (Cookies) هي ملفات نصية يتم تخزينها على القرص الصلب للمستخدم عبر المتصفح.
√	٤٢	من مخاطر الكوكيز "خطف الكوكيز" و"التلاعب بمحتوياتها".
X	٤٣	يهدف هجوم البرمجة عبر المواقع (XSS) إلى اختراق موقعك كهدف أساسي وليس استخدامه كجسر للضحايا.
√	٤٤	لتجنب هجمات XSS، يُنصح بعمل "قائمة بالمدخلات المسموحة (Whitelist)".
√	٤٥	في هجوم CSRF، يتم الاختراق عن طريق رابط أو كود برمجي يطلبه المستخدم دون علمه.
√	٤٦	تستطيع هجمات CSRF انتحال شخصية الضحية واستخدام حساباتها.
X	٤٧	من قواعد استخدام الإنترنت الأمن عدم إغلاق متصفح الإنترنت بعد الانتهاء من استخدامه.
√	٤٨	تُعرف "ديدان الحاسب (Worms)" بأنها برامج مستقلة لا تحتاج إلى برنامج مضيف للنشر.
√	٤٩	"أحصنة طروادة (Trojan Horses)" هي برامج خبيثة تبدو وكأنها برمجيات سليمة لخداع المستخدم.
√	٥٠	"البوت نت (Botnet)" هو مجموعة أجهزة متصلة بالإنترنت مصابة ويتم التحكم بها عن بُعد.
√	٥١	ملفات تعريف الارتباط (Cookies) هي ملفات نصية يتم تخزينها على القرص الصلب للمستخدم عبر المتصفح.
√	٥٢	يستخدم التشفير المتماثل مفتاحاً واحداً فقط لعمليتي تشفير وفك تشفير البيانات.
√	٥٣	من أمثلة خوارزميات التشفير المتماثل تقنيات AES و DES.
X	٥٤	يتميز التشفير المتماثل بمستوى أمان أعلى من التشفير غير المتماثل لعدم حاجته لمشاركة المفاتيح.
√	٥٥	التشفير غير المتماثل يتضمن استخدام زوج من المفاتيح (مفتاح عام ومفتاح خاص).

√	يُستخدم بروتوكول HTTPS والبريد الإلكتروني المشفر كتطبيقات عملية للتشفير غير المتماثل.	٥٦
X	بنية البنية التحتية للمفاتيح العامة (PKI) تدعم التشفير المتماثل من خلال الشهادات الرقمية.	٥٧
√	تقنية SSL/TLS تُستخدم لتأمين نقل البيانات عبر الشبكات وحمايتها من التجسس.	٥٨
√	يُعد تشفير النسخ الاحتياطي ضرورياً لحماية البيانات في حالة سرقة أو فقد الجهاز.	٥٩

السؤال الثاني: اختر الإجابة الصحيحة من بين الإجابات التالية: [١٠ درجات - لكل نقطة درجة]

ما المقصود بـ "الأصل (Asset)" في إدارة المخاطر؟			١
أ	التهديد الخارجي للنظام	ج	
ب	نقطة الضعف في النظام	د	
أي من التالي يُعتبر مثالاً على "ثغرة (Vulnerability)"؟			٢
أ	فيروس كمبيوتر	ج	
ب	كلمة مرور ضعيفة	د	
أي من التالي يُعبر عن "Phishing"؟			٣
أ	برنامج لتسريع الجهاز	ج	
ب	نوع من الفيروسات فقط	د	
أي مما يلي يُعد من مراحل إدارة المخاطر؟			٤
أ	التصميم فقط	ج	
ب	التحديد والتحليل والاستجابة	د	
ماذا تعني مرحلة "Identification"؟			٥
أ	معالجة الخطر	ج	
ب	تحديد الأصول والتهديدات	د	
ماذا يدل اللون الأحمر في مصفوفة المخاطر؟			٦
أ	خطر منخفض	ج	
ب	خطر متوسط	د	
أي مما يلي يُعتبر تهديد (Threat)؟			٧
أ	كلمة مرور ضعيفة	ج	
ب	فيروس أو هكر	د	
ما معنى "Transfer" في إدارة المخاطر؟			٨
أ	حذف الخطر	ج	
ب	تجاهل الخطر	د	
أي مما يلي يُعد مثال على "Asset"؟			٩
أ	بيانات العملاء	ج	
ب	موظف مخترق	د	
لماذا نستخدم مصفوفة المخاطر؟			١٠
أ	لتشفير الملفات	ج	
	لتخزين البيانات		

ب	لتحديد أولويات المخاطر	د	لتسريع الكمبيوتر
ما أهمية وجود خطة استمرارية الأعمال؟			
أ	حذف البيانات	ج	استعادة العمل بعد الاختراق
ب	تقليل عدد الأجهزة	د	زيادة المبيعات
ما المقصود بالهوية الرقمية؟			
أ	جهاز الكمبيوتر	ج	بيانات تمثل الشخص على الإنترنت
ب	كلمة المرور فقط	د	رقم الهاتف فقط
أي من التالي يُعد مصدر تهديد خارجي؟			
أ	مدير النظام	ج	شريك عمل
ب	قرصنة الإنترنت	د	موظف داخل الشركة
ما الهدف من تشفير البيانات؟			
أ	تقليل حجم الملفات	ج	منع الوصول غير المصرح
ب	حذف البيانات	د	تسريع البيانات
أي من التالي يُعد من تحديات الهوية الرقمية؟			
أ	تحديث النظام	ج	ضعف التوعية
ب	سرعة الإنترنت	د	زيادة الأمان
أي من التالي يُعتبر خطر مرتفع؟			
أ	احتمال منخفض وتأثير عالي	ج	احتمال منخفض وتأثير منخفض
ب	احتمال عالي وتأثير عالي	د	لا شيء
ما أهمية التحديثات الأمنية؟			
أ	تقليل المساحة	ج	حذف البرامج
ب	سد الثغرات	د	تقليل السرعة
ما هو نوع البرمجيات الخبيثة الذي ينتشر تلقائياً عبر الشبكات دون الحاجة لملف مضيف؟			
أ	الفيروسات	ج	برامج الإعلانات
ب	أحصنة طروادة	د	الديدان
ما هو الهدف الأساسي لهجوم "البرمجة عبر المواقع" (XSS) عند استغلال ثغرات المواقع؟			
أ	إيقاف البريد	ج	تخمين كلمة مرور المدير
ب	سرقة بيانات جلسة الضحية من المتصفح	د	تشفير الخادم
على ماذا يعتمد هجوم (CSRF) لتنفيذ عمليات غير مصرح بها باسم المستخدم دون علمه؟			
أ	تخمين كلمة المرور	ج	تسجيل ضربات المفاتيح
ب	استغلال جلسة عمل نشطة	د	قطع الإنترنت
ماذا نطلق على شبكة الأجهزة المخترقة التي يُحكم بها عن بُعد لتنفيذ هجمات واسعة؟			
أ	خادم الويب	ج	البوت نت (Botnet)
ب	الجدار الناري	د	الفدية

أي من الأدوات التالية تُستخدم لتأمين "البيانات أثناء السكون" وحمايتها في حال ضياع الأجهزة؟			
٢٢	أ	بروتوكولات SSL/TLS	جـ برنامج VeraCrypt للأقراص.
	ب	أداة GPG للبريد.	د الشهادات الرقمية للمتصفح.
أي أداة تُستخدم لمراقبة العمليات التي تتصل بالشبكة وحجم البيانات المرسلة في الوقت الفعلي؟			
٢٣	أ	عارض الأحداث (Event Viewer)	جـ تشفير الملفات (EFS)
	ب	مراقب الموارد (Resource Monitor)	د خصائص المجلد (Properties)
عند الرغبة في رؤية سجلات الدخول والخروج في ويندوز، ما هو المسار الصحيح داخل عارض الأحداث؟			
٢٤	أ	Application Logs > Security	جـ Windows Logs > Security
	ب	Windows Logs > System	د Setup Logs > Security
لضمان عدم قدرة الآخرين على تعديل أو حذف محتويات مجلد مشترك على الشبكة، يجب ضبط الصلاحيات على:			
٢٥	أ	Read/Write	جـ Full Control
	ب	Change	د Read

السؤال الثالث: أجب عن الأسئلة التالية [٣٠ درجة]

١	وضح الدور الذي يلعبه "سجل الأحداث" (Event Viewer) في عملية التحقيق الجنائي الرقمي (Digital Forensics) عند الاشتباه في اختراق لنظام التشغيل ويندوز.	[١٠ درجات]
---	--	------------

يعتبر عارض الأحداث بمثابة "الصندوق الأسود" للنظام؛ حيث يقوم بتسجيل كافة الأنشطة الحيوية التي تتم على مستوى النظام والتطبيقات والأمن. تكمن أهميته في:

- **تتبع الوصول (Access Tracking):** من خلال مراقبة سجلات الأمان (Security Logs)، يمكن للمحقق تحديد محاولات تسجيل الدخول الناجحة (Event ID 4624) والفاشلة (Event ID 4625)، مما يساعد في كشف هجمات التخمين (Brute Force).
- **تحديد الجدول الزمني (Timeline Analysis):** يساعد في بناء تسلسل زمني دقيق للحادثة، مثل معرفة متى تم تسجيل الخروج (Event ID 4634) وحساب المدة الزمنية التي قضاها المهاجم داخل النظام.
- **كشف الأنشطة غير الاعتيادية:** رصد الدخول في أوقات غير رسمية أو من حسابات ذات صلاحيات عالية، مما يمثل دليلاً رقمياً قانونياً يمكن استخدامه في المحاكم أو التحقيقات الإدارية.

٢	قارن بين استخدام "مراقب الموارد" (Resource Monitor) وأدوات الحماية التقليدية في اكتشاف تسريب البيانات (Data Exfiltration).	[١٠ درجات]
---	--	------------

بينما تركز أدوات الحماية التقليدية (مثل مضادات الفيروسات) على اكتشاف البرمجيات الخبيثة بناءً على التوقعات، يوفر "مراقب الموارد" تحليلاً سلوكياً حياً: (Real-time Behavioral Analysis)

- **مراقبة الشبكة:** يتيح مراقب الموارد رؤية العمليات (Processes) التي تستهلك عرض النطاق الترددي (Bandwidth) حالياً، وتحديد عناوين الـ IP التي تتواصل معها، مما يكشف عن عمليات نقل البيانات الضخمة التي قد لا تكتشفها الجدران النارية فوراً.
- **تحليل النشاط:** يساعد في ربط العملية البرمجية بحجم البيانات المرسل؛ فإذا لوحظ أن برنامجاً بسيطاً يقوم بإرسال جيجابايت من البيانات للخارج، فإن هذا يعد مؤشراً قوياً على وجود "تسريب بيانات".

٣	ناقش مفهوم "الدفاع بالعمق" (Defense in Depth) من خلال تطبيق تقنيات التشفير (EFS) وإدارة الصلاحيات (Permissions) على المجلدات المشتركة.	[١٠ درجات]
---	--	------------

يعتمد مبدأ الدفاع بالعمق على وضع طبقات متعددة من الحماية لضمان أمن البيانات حتى في حال اختراق الطبقة الخارجية:

- **الطبقة الأولى (الصلاحيات):** ضبط صلاحيات المشاركة (Sharing Permissions) مثل وضعها على "Read Only" يمنع المستخدمين غير المصرح لهم من تعديل أو حذف البيانات، وهو خط الدفاع الأول ضد التخريب غير المتعمد أو المقصود.
- **الطبقة الثانية (تشفير):** EFS يعمل تشفير ملفات النظام (EFS) كطبقة حماية داخلية؛ فحتى لو استطاع المهاجم الوصول إلى المجلد أو نسخ الملفات عبر الشبكة، فلن يتمكن من فتح محتواها أو قراءته لأنها مشفرة بمفتاح خاص مرتبط بالمستخدم الأصلي فقط (تظهر علامة القفل).
- **التكامل:** هذا الجمع يضمن سرية البيانات (Confidentiality) من خلال التشفير، وسلامتها (Integrity) من خلال الصلاحيات.

٤	ما هي الخطوات المنهجية التي يجب على مسؤول أمن المعلومات اتخاذها عند رصد "تشاط مشبوه" على أحد أجهزة الشبكة؟	[١٠ درجات]
---	--	------------

يجب اتباع بروتوكول الاستجابة للحوادث (Incident Response) المكون من الخطوات التالية:

١. **العزل: (Isolation)** فصل الجهاز فوراً عن الشبكة (قطع الواي فاي أو كابل الإيثرنت) لمنع انتشار التهديد (Lateral Movement) أو استمرار تسريب البيانات.
٢. **التحليل: (Analysis)** فحص سجلات الأمان في عارض الأحداث ومراقبة العمليات النشطة لتحديد نوع التهديد ومصدره.
٣. **الاحتواء: (Containment)** تأمين الحسابات المتضررة وتغيير كلمات المرور من جهاز سليم (خارج البيئة المصابة).
٤. **التعافي: (Recovery)** تطهير الجهاز أو استعادة النسخ الاحتياطية بعد التأكد من سد الثغرة التي استغلها المهاجم.

انتهت الاسئلة

مع تمنياتي بالتوفيق،،،

أسلوب الإجابة فى الامتحان

السؤال الأول :

- ١- كتابة في ورقة مستقلة "إجابة السؤال الأول"
- ٢- لا يتم كتابة الأسئلة في ورقة الإجابة
- ٣- يتم عمل جدول مكون من ٢ عمود فقط كما بالتالي

رقم السؤال	الاجابة
١	√
٢	X
٣	√
٤	√
٥	X
٦	√
٧	X
٨	X
٩	√
١٠	√

السؤال الثاني :

- ١- كتابة في ورقة مستقلة "إجابة السؤال الثاني"
- ٢- لا يتم كتابة الأسئلة في ورقة الإجابة
- ٣- يتم عمل جدول مكون من ٣ عمود فقط كما بالتالي

رقم السؤال	رقم الإجابة الصحيحة	الاجابة
١	أ	كتابة الاختيار الصحيح
٢	ب	كتابة الاختيار الصحيح
٣	د	كتابة الاختيار الصحيح
٤	أ	كتابة الاختيار الصحيح

السؤال الثالث :

- ١- كتابة في ورقة مستقلة "إجابة السؤال الثالث رقم (أ)"
- ٢- كتابة في ورقة مستقلة "إجابة السؤال الثالث رقم (ب)"
- ٣- كتابة في ورقة مستقلة "إجابة السؤال الثالث رقم (ج)"
- ٤- لابد من كتابة السؤال في ورقة الإجابة